

A real world look into Privacy Engineering and Privacy by Design: Privacy Risk Assessments

Dquez Carr
MCY 620-Data Privacy
Northern Kentucky University
Highland Heights, KY, USA
carrd12@mymail.nku.edu

Abstract- As more and more personal data is gathered, processed, and shared by companies, privacy dangers are rising. A methodical approach to detecting, evaluating, and reducing risks to individuals resulting from data processing operations is offered by Privacy Risk Assessment. This study looks at Privacy Risk Assessment as a fundamental technique in Privacy by Design and information privacy engineering. It examines important ideas, objectives, approaches, and practical applications, showing how PRA promotes risk mitigation, regulatory compliance, and reliable system design. The study makes the case that developing strong, legal, and user friendly information systems requires including privacy risk assessment early in the system lifecycle.

Keywords- Privacy Risk Assessment, Privacy Engineering, Privacy by Design, Data Protection, Information Privacy, Risk Management

I INTRODUCTION

Businesses are depending more and more on data driven systems, which increases the dangers to individual privacy due to misuse, overcollection, unauthorized access, and secondary use of personal data [1][2][6]. The necessity for organized approaches to privacy protection has been highlighted by high profile data breaches and growing privacy rules [2][6][7]. A crucial tool for spotting and reducing privacy risks before they cause harm is a privacy risk assessment [1][2][11]. In order to manage privacy risks

and ensure that system design complies with organizational, legal, and ethical requirements, this paper presents Privacy Risk Assessment as a fundamental technique [1][7][14].

The goal of Privacy Risk Assessments are structured methods of identifying privacy risks, weaknesses, and possible effects on people whose data a system processes is known as privacy risk assessment [1][2][11]. Understanding how personal data moves through a system, assessing risks to confidentiality, integrity, and proper usage, and choosing measures to lessen detected risks are the main objectives of privacy risk assessments [1][6][11]. By striking a balance between business goals and individual privacy rights and expectations, privacy risk assessment facilitates well informed decision making [1][2].

II RELEVANCE & MOTIVATION

When you consider the early days of digital systems, the development of data driven technology in the present era is nearly impossible to comprehend. What started out as straightforward databases and local recordkeeping has quickly developed into cloud services, mobile apps, networked gadgets, and AI enabled platforms that gather and handle vast amounts of personal data [2][6][21]. These days, businesses rely on data to provide everything from banking and healthcare to daily convenience and education [2]. Because of this one of the most important and accessible resources in contemporary systems is personal data [6]. Due to this exposure,

privacy is now a daily worry for engineers, companies, and the general public rather than just a nice to have feature [1][2].

The increasing disparity between the amount of data acquired and the degree to which its threats are recognized is one of the main problems these systems encounter [1][2]. People frequently don't know where their data goes, who can access it, or how it might be used for purposes other than those for which it was intended. Insider misuse, ransomware events, breaches, and unintentional misconfigurations continue to demonstrate how quickly data can be exposed when privacy measures are not incorporated early on [2][6]. Complexity works against organizations, even when they have the best of intentions. Personal data is transferred between suppliers, APIs, analytics tools, and third-party services in ways that are hard to monitor. Identity theft, discrimination, loss of secrecy, and erosion of trust are among the privacy damages that are more likely to occur in this setting [1][2].

Although privacy standards and laws offer valuable direction, they do not always ensure that systems are designed safely [1][7][11]. Organizations are encouraged to detect risks, restrict needless data gathering, and secure personal information throughout its lifespan by frameworks and laws like GDPR, sector based privacy regulations in the US, and guidance from standards like those enforced by NIST [2][4][6][7]. Converting these general needs into decisions at the system level, such as what data is actually required, where it should be stored, who should have access, and what security measures should be taken, is the practical difficulty. Because it defines privacy expectations by methodically detecting privacy threats, assessing their impact, and choosing policies that lower risk in easily recorded ways, privacy risk assessment becomes crucial in this situation [1][2][11].

Privacy Risk Assessment is especially important because it directly supports privacy engineering and Privacy by Design [1][13][14]. Early risk assessment allows engineers to minimize unnecessary exposure by data minimization, enforce least privilege through role based access decisions, and enhance accountability through clear governance, logging, and monitoring [3][4][14]. By outlining the

dangers, the rationale behind specific design decisions, and the long term maintenance of protections, Privacy Risk Assessment further enhances openness. The purpose of this article is to clarify what privacy risk assessment is, why it is important, how it fits into privacy engineering processes, and how it assists businesses in creating systems that are more secure, reliable, and compliant by design [1][2][11][14].

III RESEARCH QUESTIONS

This paper is guided by the following research questions:

- How does Privacy Risk Assessment support effective privacy engineering practices?
- What role does Privacy Risk Assessment play in implementing Privacy by Design principles?
- How can Privacy Risk Assessment reduce both organizational risk and individual privacy harm?
- What challenges do organizations face when integrating PRA into system development lifecycles?

IV PRA METHODOLOGIES

When compared to the early days of simple recordkeeping and local databases, the way businesses gather and use personal data now is nearly unrecognizable [2][6]. In order to produce insights, automate choices, and customize services, modern systems frequently combine data from mobile apps, cloud services, web platforms, identity providers, and third-party analytics tools. Simple transactions like logging in, making a purchase, or setting up an appointment can set off a number of background operations that store, exchange, and modify personal data between systems. Because they offer organized means to comprehend what data is being processed, why it is being handled, and how that processing could put people at risk or cause harm, Privacy Risk Assessment approaches have become increasingly important as this data ecosystem has grown [1][2][11].

The Data Protection Impact Assessment method is frequently linked to privacy governance and regulatory driven privacy initiatives. A typical pattern for DPIA style evaluations is to describe the system or project, map the flows of personal data, determine the legitimate basis or purpose for

processing, assess need and proportionality, and then analyze risks to individuals along with suggested mitigations. In actuality, this approach compels teams to provide answers to fundamental concerns at an early stage: what personal information is gathered, what is actually needed, who will access it, where it will be kept, how long it will be kept, and what circumstances lead to sharing with third parties. Because it transforms privacy into a recorded decision process with transparent outputs, risk ratings, control choices, and reviewable accountability proof, DPIA based privacy risk assessment is particularly successful [7][8][10][11].

Instead of viewing privacy as merely a necessity for compliance, another significant methodology for assessing privacy risk stresses privacy risk through a structured, repeatable risk model. One popular example is the NIST style privacy risk method, which helps teams link system design decisions to actual privacy outcomes by framing privacy risk in terms of problematic data behaviors and possible consequences to individuals. By tackling harms like excessive collection, secondary usage, inference, re-identification, and lack of transparency, this approach extends beyond breach-focused thinking [1][2][17]. When applied appropriately, risk modeling techniques assist engineers in connecting privacy risks to particular controls such as encryption, logging, monitoring, data minimization, purpose limitation, and access enforcement [3][4][6]. As risk varies when data flows, vendors, or functionality change, they advise teams to approach privacy risk assessment as a component of the system lifecycle rather than as a singular event [1][3][13].

In addition, teams can systematically detect potential privacy failures spanning collection, processing, storage, sharing, and deletion by using techniques like data flow driven analysis and privacy threat taxonomies. Because it enables teams to identify privacy risks at the design level where trust boundaries exist, where identifiers are introduced, where linking can occur, and where monitoring or control holes may disclose sensitive attributes, this type of privacy risk assessment is particularly useful in complex systems. The most practical approach is to combine multiple approaches: threat modeling to

identify design related privacy flaws before deployment, a risk model for consistent scoring and prioritization, and a DPIA style governance procedure for accountability [7][11][15][16].

V CHALLENGES & LIMITATIONS

When privacy risk assessment is first introduced, it can appear surprisingly simple, particularly if it is described as a checklist like procedure for identifying risks, rating them, and implementing safeguards. Modern systems hardly behave like their organized layouts in real life. Data flows through mobile devices, cloud services, SaaS providers, and analytics pipelines in ways that can change quickly in response to new features, integrations, and business needs [1][2][11][21]. A well scoped assessment can easily turn into a complicated endeavor to map data flows, establish boundaries, and reach a consensus on what privacy risk actually entails in a particular situation. Privacy risk assessment is more important as businesses grow more digitally connected, but it is also more difficult to perform consistently and accurately [1][2].

Instead of viewing privacy as merely a necessity for compliance, another significant methodology for assessing privacy risk stresses privacy risk through a structured, repeatable risk model. One of the constraints of privacy risk assessment is that, unlike typical cybersecurity risk, privacy risk is hard to quantify. While privacy impact might be indirect, delayed, or challenging to measure, security evaluations frequently concentrate on obvious incidents like breaches, outages, or exploitation. Even though risks like prejudice, secondary usage, inference, and profiling might not manifest as occurrences right away, they can nevertheless seriously hurt people. Additionally, privacy risk assessments rely significantly on presumptions on the usage of data, who will have access to it, and potential future contexts. These presumptions may become incorrect when a system grows or its goals change. Because of this, it is difficult to assign consistent severity ratings, particularly when the impact differs among various groups and use situations [1][2][3][5].

The quality of the data used for the assessment is another significant obstacle. Teams

frequently struggle with incomplete asset inventories, ambiguous data lineage, and undocumented shadow IT activities since privacy risk assessment is only as strong as the system knowledge feeding it. When software development happens more quickly than governance updates, even when documentation is available, it might not accurately reflect the current situation. Cultural and operational hurdles are also common in many organizations: business teams may underestimate risk to save delays, engineering teams may see privacy risk assessment as a compliance obstacle, and privacy teams may not have the technical visibility required to assess complicated infrastructures. Risk assessments that are technically simplistic, too optimistic, or completed too late to have a significant impact on design choices may be the outcome [1][2][3][6][11].

Once a privacy risk assessment is finished, its sustainability and enforcement are limited. The proper implementation, long term maintenance, and reevaluation of controls as systems change are not guaranteed by a risk assessment. Long after the initial privacy risk assessments were authorized, new privacy concerns may be introduced by ongoing delivery pipelines, frequent configuration upgrades, and vendor changes [1][2][3][4]. Additionally, businesses frequently rely on outside parties for data processing, storage, and analytics, which might limit their control over data security and auditing [21]. Privacy risk assessment is not a one time document made to meet policy requirements; instead it must be viewed as a living practice connected to change management, ongoing monitoring, and responsibility [13].

VI CASE STUDIES

A. Healthcare Systems

The growth of modern healthcare technology is almost hard to understand when you compare it to the early days of paper charts and isolated hospital databases. In order to maintain the flow of care, electronic health record systems, insurance claims processors, pharmacy networks, and patient portals frequently exchange protected health information with many suppliers and organizations [6]. Healthcare is more efficient as a result of this interconnection, but it also increases the privacy risk because one hacked link could interfere with the

provision of care and reveal private information [19][20]. A high profile example is the Change Healthcare ransomware attack in 2024, which became a frequently recognized demonstration of how operational disruption and privacy harm may spread swiftly when fundamental systems supporting billing and claims are impacted [18].

One of the most critical insights in healthcare is that privacy risk assessment is not limited to who can see the data, but also covers how data flows, how it is reused, and how long it persists across systems. In a typical healthcare privacy risk assessment, teams start by mapping PHI data flows (registration, clinical documentation, labs, billing, claims adjudication, and third-party services), then identify privacy issues such as excessive collection, secondary use, over permissive access, and insufficient audibility [1]. Protections like least privilege role design, division of duties, encryption while in transit and at rest, secure authentication, and accountability supporting monitoring are then linked to these risks [3][6]. Privacy risk assessment is especially useful here since it ties Privacy by Design goals reduction, purpose limitation, transparency, and lifecycle protection to implementable security and governance policies that can be evaluated and assessed [4][11][14].

B. Cloud Platforms

A separate but equally significant case pattern is introduced by cloud platforms, where privacy risk frequently results from misconceptions about accountability and configuration. In order to achieve scalability and availability, organizations move their workloads and data into public cloud environments. However, the privacy and security results are largely dependent on proper architecture, identity setting, and ongoing oversight. Adoption of public clouds presents security and privacy issues that need to be handled with careful planning, governance, and control selection, according to the NIST. Cloud providers promote a shared responsibility paradigm where the provider secures the underlying infrastructure while users retain responsibility for securing their configurations, identities, and data [22][23]. Misconfigurations such as too broad access permissions or incorrectly shared

storage resources remain a recurring generator of exposure risk in cloud systems [21][24][25].

A healthcare company transferring analytics and reporting to a cloud data lake is a real world example of a cloud Privacy risk assessment. Even when the provider secures the physical environment, the privacy risk assessment still needs to evaluate privacy risks tied to access control decisions (overly permissive roles), data exposure pathways (misconfigured storage shares or tokens), and secondary use risks (repurposing patient data for analytics beyond the original intent). Tightly scoped IAM roles, data minimization at ingestion, encryption, key management, token time-limits for sharing, continuous configuration monitoring, and effective logging to allow detection and auditing are among the mitigations that are then prioritized by the assessment [4][22][23]. The "customer responsibility" layer identity, configuration, and monitoring rather than the underlying cloud infrastructure itself is where many errors occur, according to scholarly evaluations of significant cloud breaches [24][25].

VII FUTURE OF PRA

While modern systems are always changing due to cloud scalability, fast updates, and new integrations, Privacy Risk Assessments are becoming an ongoing activity rather than a one time document [2][21]. PRA is becoming more closely linked to the entire system lifecycle in order to maintain accuracy and usefulness over time, since privacy risk changes when data flows, vendors, and system purposes change [3][13]. Future privacy risk assessment techniques are also heading toward continuous PRA, in which automation assists in identifying modifications to data pipelines, storage, and access roles so that evaluations can be updated in parallel with DevSecOps workflows [1][4]. While better standardization would facilitate the sharing and validation of PRA results across vendors and supply chains, AI and advanced analytics are driving privacy risk assessments to address more recent issues including inference, model leakage, and unexpected secondary usage of training data [2][13][17].

VIII CONCLUSION

As it transforms privacy from a broad concept into a practical engineering procedure, privacy risk assessment is a fundamental technique [2]. Organizations can choose certain measures that lessen the possibility and impact of privacy harm by methodically identifying concerns including overcollection, unlawful access, secondary use, or excessive retention [1][6]. By promoting proactive measures including data minimization, least privilege, encryption, and auditing prior to system deployment, this method supports Privacy by Design [4][14]. By recording risk decisions, mitigation techniques, and accountability measures in a format that can be examined and verified, privacy risk assessment also aids in coordinating technical choices with operational and legal requirements [1][3][7][11].

As cloud services, mobile platforms, IoT, and AI driven analytics continue to advance, the privacy attack surface grows and is more difficult to control with ad hoc choices alone [21]. As systems grow and evolve, Privacy Risk Assessments offer a repeatable approach to preserving compliance, lowering corporate exposure, and boosting user confidence [3]. When privacy risk assessment is integrated into the system lifecycle from planning and design to deployment and continuous monitoring it becomes a useful method for creating information systems that are not just functional but also safe, compliant, and deserving of public trust [1][2][13][14].

REFERENCE

- [1] S. Brooks, M. Garcia, N. Lefkowitz, S. Lightman, and E. Nadeau, "An Introduction to Privacy Engineering and Risk Management in Federal Systems," *NIST Interagency Report (NISTIR) 8062*, Jan. 2017, doi: 10.6028/NIST.IR.8062.
- [2] N. Lefkowitz and K. R. Boeckl, "NIST Privacy Framework: A Tool for Improving Privacy through Enterprise Risk Management, Version 1.0," *NIST Cybersecurity White Paper (CSWP) 01162020*, Jan. 2020, doi: 10.6028/NIST.CSWP.01162020.
- [3] Joint Task Force, "Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and

Privacy,” *NIST Special Publication (SP) 800-37 Rev. 2*, Dec. 2018, doi: 10.6028/NIST.SP.800-37r2.

[4] Joint Task Force, “Security and Privacy Controls for Information Systems and Organizations,” *NIST SP 800-53 Rev. 5*, Sep. 2020, doi: 10.6028/NIST.SP.800-53r5.

[5] J. Scarfone, M. Souppaya, A. Cody, and A. Orebaugh, “Guide for Conducting Risk Assessments,” *NIST SP 800-30 Rev. 1*, Sep. 2012, doi: 10.6028/NIST.SP.800-30r1.

[6] E. McCallister, T. Grance, and K. Scarfone, “Guide to Protecting the Confidentiality of Personally Identifiable Information (PII),” *NIST SP 800-122*, Apr. 2010, doi: 10.6028/NIST.SP.800-122.

[7] European Parliament and Council of the European Union, “Regulation (EU) 2016/679 (General Data Protection Regulation),” *Official Journal of the European Union*, L 119, May 4, 2016 (see Art. 35: DPIA).

[8] Article 29 Data Protection Working Party, “Guidelines on Data Protection Impact Assessment (DPIA) and determining whether processing is ‘likely to result in a high risk’ for the purposes of Regulation 2016/679,” WP248 rev.01, Oct. 13, 2017.

[9] Commission Nationale de l’Informatique et des Libertés (CNIL), “PIA, Methodology (February 2018 edition),” Feb. 2018.

[10] Information Commissioner’s Office (ICO), “Data Protection Impact Assessments (DPIAs),” UK GDPR Guidance, May 19, 2023. Accessed: Feb. 2, 2026.

[11] ISO/IEC, “ISO/IEC 29134:2017 Information technology—Security techniques—Guidelines for privacy impact assessment,” ISO/IEC, 2017.

[12] ISO/IEC, “ISO/IEC 29100:2011 Information technology—Security techniques—Privacy framework,” ISO/IEC, 2011.

[13] ISO/IEC, “ISO/IEC TR 27550:2019 Security techniques—Privacy engineering for system life cycle processes,” ISO/IEC, 2019.

[14] A. Cavoukian, “Privacy by Design: The 7 Foundational Principles,” Information and Privacy Commissioner of Ontario, 2011.

[15] K. Wuyts, R. Scandariato, and W. Joosen, “Empirical evaluation of a privacy-focused threat modeling methodology,” *Journal of Systems and Software*, vol. 96, pp. 122–138, Oct. 2014, doi: 10.1016/j.jss.2014.05.075.

[16] K. Wuyts, D. Van Landuyt, A. Hovsepyan, and W. Joosen, “Effective and Efficient Privacy Threat Modeling through Domain Refinements,” in *Proc. ACM Symposium on Applied Computing (SAC)*, 2018, doi: 10.1145/3167132.3167414.

[17] S. L. Garfinkel, “De-Identification of Personal Information,” *NISTIR 8053*, Oct. 2015, doi: 10.6028/NIST.IR.8053.

[18] G. P. Kanter, J. R. Rekowski, and J. T. Kannarkat, “Lessons From the Change Healthcare Ransomware Attack,” *JAMA Health Forum*, vol. 5, no. 9, 2024, doi: 10.1001/jamahealthforum.2024.2764.

[19] J. X. Jiang, J. S. Ross, and G. Bai, “Ransomware Attacks and Data Breaches in US Health Care Systems,” *JAMA Network Open*, vol. 8, no. 5, 2025, doi: 10.1001/jamanetworkopen.2025.10180.

[20] U.S. Department of Health & Human Services, “Change Healthcare Cybersecurity Incident Frequently Asked Questions,” 2025.

[21] W. Jansen and T. Grance, “Guidelines on Security and Privacy in Public Cloud Computing,” *NIST SP 800-144*, 2011, doi: 10.6028/NIST.SP.800-144.

[22] Amazon Web Services, “Shared Responsibility Model,” AWS Documentation/Whitepaper.

[23] Microsoft, “Shared responsibility in the cloud – Azure,” Microsoft Learn, 2026.

[24] S. Khan *et al.*, “A Systematic Analysis of the Capital One Data Breach,” *ACM Computing Surveys*, 2022, doi: 10.1145/3546068.

[25] Wiz Research, “38 terabytes of private data accidentally exposed by Microsoft AI researchers,” 2023.